



Introduction to Data Protection and GDPR

Name:		Grade:	
Date completed:		Approved by:	
Valid for:		Signature:	

Introduction to Data Protection and GDPR

Welcome to this lesson on

THE GENERAL DATA PROTECTION REGULATION (GDPR)

LAUNCH

Introduction to Data Protection and GDPR

Learning objectives

In this lesson, we will discuss:

- Purpose and basis of the GDPR
- Rights of individuals under the GDPR
- Data controllers, data processors and their responsibilities
- Data Protection Officers and their tasks
- Regulatory Authorities for the GDPR
- Consequences of non-compliance



Introduction to Data Protection and GDPR

History of Data Protection

The OECD Guidelines and the data protection directive paved the way for the GDPR.

- Based on recommendations from countries across the world
- Adopted on 23rd September 1980
- Eight Principles for processing personal data
- Guidelines were non-binding
- Levels of data protection varied between states



01 OECD Guidelines

- Adopted on 24th October 1995
- **Goals:**
 - Harmonising data protection laws
 - Provide rules for transferring data to third countries
- **Established DPAs to:**
 - Supervise application of the directive
 - Serve as a regulatory body

02 Directive 95/46/EC

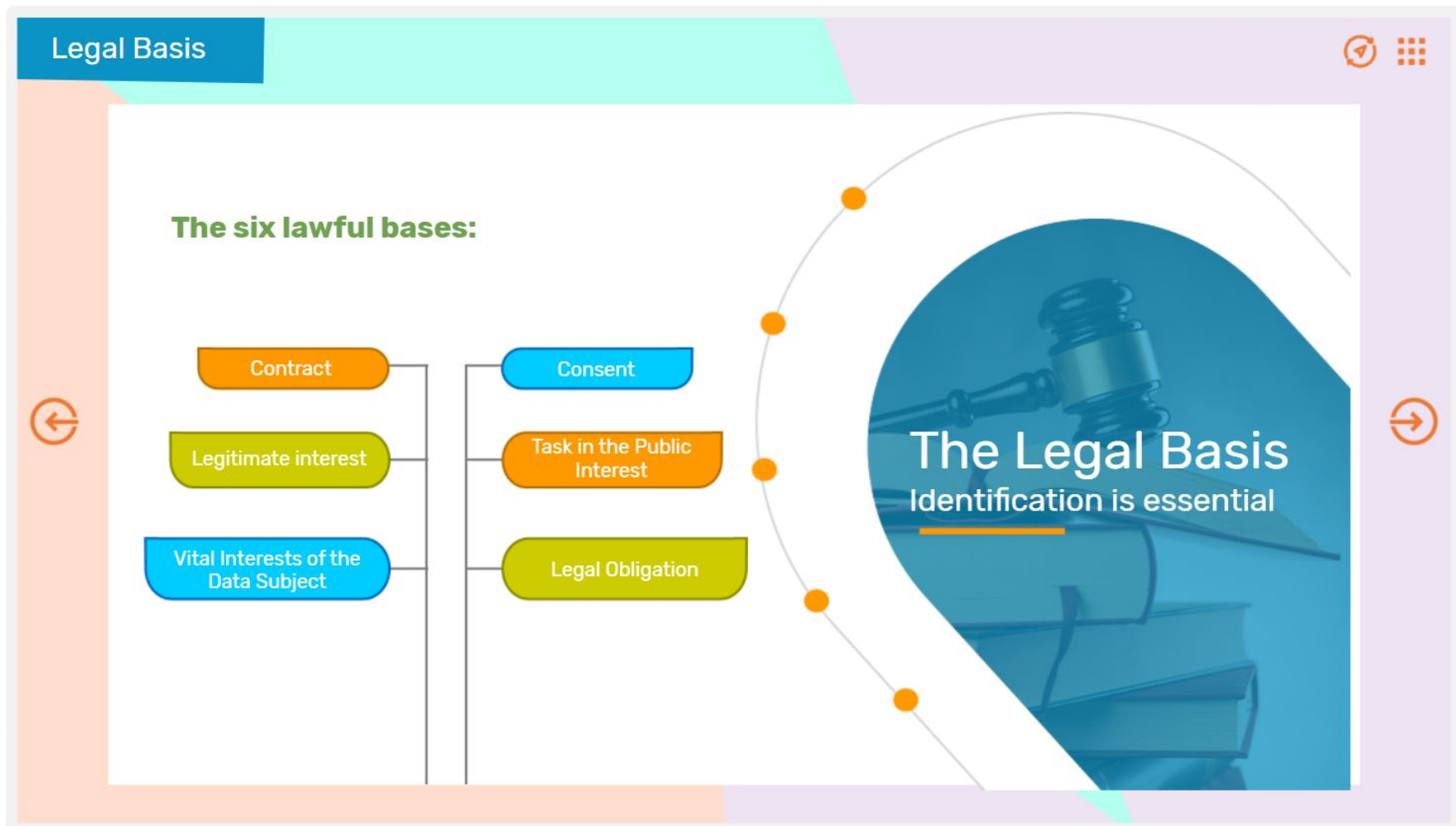
- Directive 95/46/EC left some room for interpretation when forming national laws
- GDPR became enforceable law in all EU member states
- The GDPR has updated the standards to fit today's technology

03 GDPR

- Updates the 1998 law
- Sits alongside GDPR and tailors how it applies in UK
- Contains 4 parts:
 - General processing under GDPR
 - General Processing-applied GDPR
 - Law enforcement processing
 - Intelligence service processing

04 Data Protection Act 2018

Introduction to Data Protection and GDPR



Introduction to Data Protection and GDPR

Legal Basis

The GDPR enhances the protection of individuals' rights in relation to their personal data.

The correct lawful basis should be identified before processing begins and should not be changed without good reason.

Special category data needs to have a lawful basis and an additional condition for processing this data.



The Legal Basis
Identification is essential

Introduction to Data Protection and GDPR

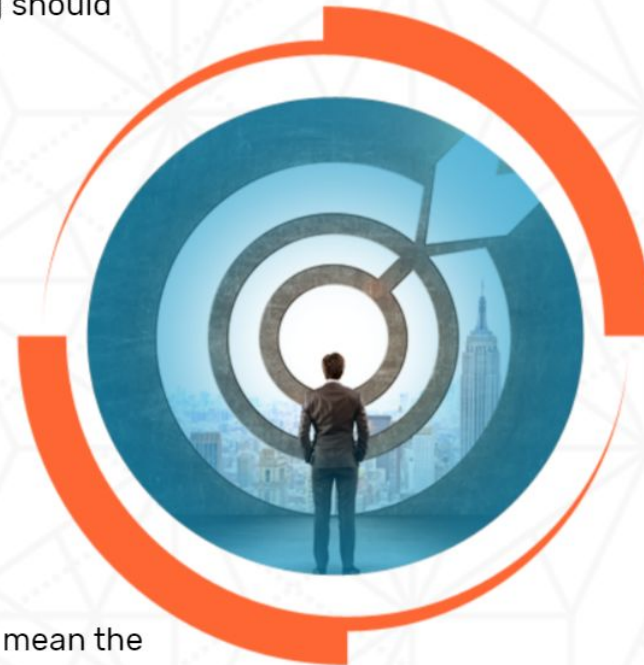
The Principles

In addition to the lawful bases, all processing should happen with the principles at the heart.

Seven Data Principles:

- 01 Lawfulness, fairness and transparency
- 02 Purpose limitation
- 03 Data minimisation
- 04 Accuracy
- 05 Storage limitation
- 06 Integrity and confidentiality (security)
- 07 Accountability

Failing to comply with these principles could mean the organisation faces a fine under the GDPR.



Introduction to Data Protection and GDPR

Key Definitions

→ Click each term to view the definition.

Data Subject

Personal Data

Special Category Personal Data

A data subject is a natural person whose personal data is processed by a controller or processor.

Introduction to Data Protection and GDPR

Key Definitions

→ Click each term to view the definition.

Data Subject

Personal Data

Special Category Personal Data

Personal data is any information related to a natural person or 'data subject', that can be used to directly or indirectly identify the person.

Introduction to Data Protection and GDPR

Key Definitions

→ Click each term to view the definition.

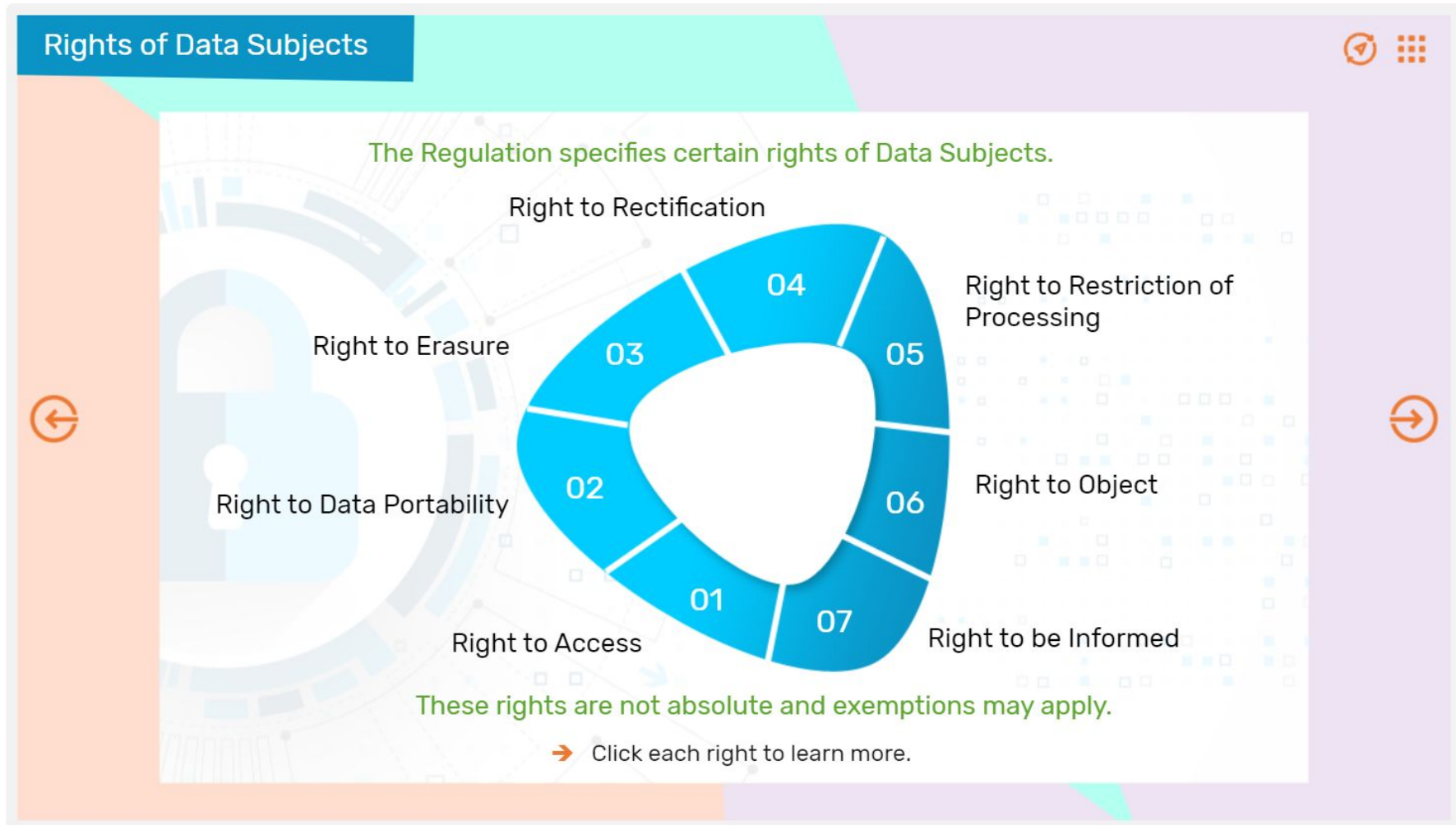
Data Subject

Personal Data

Special Category Personal Data

Special Category Personal Data is Personal data containing information relating to an individual's; racial and ethnic origin, political opinions, religious beliefs, trade union membership, physical or mental health, sexual life, or criminal history.

Introduction to Data Protection and GDPR



Introduction to Data Protection and GDPR

The slide is titled "Rights of Data Subjects" in a dark blue header. The main content area has a dark background with a faint circular graphic. A text box states: "The Regulation specifies certain rights of Data Subjects." Below this, a pie chart shows two segments: "01 Right to Access" and "07 Right to be Informed". A white pop-up box with a blue header "Right to Access" and a close button (X) is overlaid. It contains a list of points about the right to access. At the bottom of the slide, it says "These rights are not absolute and exemptions may apply." followed by a right arrow and the text "Click each right to learn more."

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

Right to Access

- GDPR gives data subjects the right to obtain confirmation from the data controller as to:
 - Whether their personal data is being processed
 - Where is it being processed
 - Purpose for which it is being processed
- The controller has to provide a copy of this information to the data subject free of charge
- The controller has to provide such information within one month from the date of the receipt of the request

01 Right to Access

07 Right to be Informed

These rights are not absolute and exemptions may apply.

→ Click each right to learn more.

Introduction to Data Protection and GDPR

The slide is titled "Rights of Data Subjects" in a dark blue header. The main content area has a grey background with a faint circular diagram. A blue modal box is open in the center, titled "Right to Data Portability" with a close button (X) in the top right corner. The modal contains a list of four points, each preceded by an orange square bullet. The background slide text includes "The Regulation specifies certain rights of Data Subjects." at the top, "Right to Rectification" and "Right to Restriction of" in the upper middle, "Right to Access" with a checkmark icon in the lower left, "Right to be Informed" in the lower right, and "These rights are not absolute and exemptions may apply." at the bottom, followed by a right-pointing arrow and the text "Click each right to learn more." The circular diagram in the background has segments labeled "01" and "07".

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

Right to Rectification

Right to Restriction of

Right to Data Portability

- The data subject will be able to receive their personal data
- They will be able to transfer their data to another controller
- Data can be moved, copied or transferred
- It only applies to information the data subject has given to the controller

Right to Access

Right to be Informed

These rights are not absolute and exemptions may apply.

➔ Click each right to learn more.

Introduction to Data Protection and GDPR

The slide is titled "Rights of Data Subjects" in a dark blue header. The main content area has a dark background with a faint grid pattern. A green text box at the top states: "The Regulation specifies certain rights of Data Subjects." Below this, a blue pop-up window titled "Right to Erasure" with a close button (X) is displayed. The pop-up contains a list of points: a blue square bullet point followed by "Also known as the 'Right to be forgotten'", a blue square bullet point followed by "The data subject can ask the controller to erase personal data concerning them", and a blue square bullet point followed by "The controller will have the obligation to do so without undue delay if:". Under the last point, there are seven orange square bullet points: "The data is no longer required for the original purpose", "The data subject withdraws consent and there is not legal ground for processing", "The data subject objects to the processing", "The data has been unlawfully processed", "The data has to be erased for complying with a legal obligation", and "The data has been collected in relation to the offer of information society services". Below the pop-up, green text states: "These rights are not absolute and exemptions may apply." At the bottom, a green arrow points to the text: "Click each right to learn more."

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

Right to Erasure

- Also known as the 'Right to be forgotten'
- The data subject can ask the controller to erase personal data concerning them
- The controller will have the obligation to do so without undue delay if:
 - The data is no longer required for the original purpose
 - The data subject withdraws consent and there is not legal ground for processing
 - The data subject objects to the processing
 - The data has been unlawfully processed
 - The data has to be erased for complying with a legal obligation
 - The data has been collected in relation to the offer of information society services

These rights are not absolute and exemptions may apply.

➔ Click each right to learn more.

Introduction to Data Protection and GDPR

The screenshot shows a web application interface with a dark blue header bar containing the text "Rights of Data Subjects". Below the header, a large grey area contains the text "The Regulation specifies certain rights of Data Subjects." and "Right to Rectification". A white pop-up window with a blue header bar titled "Right to Rectification" is overlaid on the page. The pop-up contains a list of four points, each preceded by an orange square bullet point. The background of the application shows a circular progress indicator with segments labeled "01" and "07", and other rights listed with checkmarks: "Right to Access" and "Right to be Informed". At the bottom of the grey area, it says "These rights are not absolute and exemptions may apply." and "Click each right to learn more." with a right-pointing arrow.

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

Right to Rectification

Right to Rectification

- The data subject has the right to ask the controller for rectification of inaccurate personal data regarding them
- They will have the right to have the incomplete personal data completed
- The request for rectification may be verbal or in writing
- The organisations have one month to respond to such a request

Right to Access

Right to be Informed

These rights are not absolute and exemptions may apply.

→ Click each right to learn more.

Introduction to Data Protection and GDPR

The slide is titled "Rights of Data Subjects" in a dark blue header. The main content area has a dark background with a grid of icons. A modal window with a blue header "Right to Restriction of Processing" is open, displaying a list of conditions. The background text includes "The Regulation specifies certain rights of Data Subjects." and "These rights are not absolute and exemptions may apply." with a prompt to "Click each right to learn more."

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

Right to Restriction of Processing

- The data subject can exercise this right where:
 - The accuracy of the data is contested, till the controller verifies the accuracy of the data
 - Processing is unlawful and the data subject requests restriction instead of erasure of data
 - The controller does not need the data for processing, but it is required by the data subject for the establishment, exercise or defence of legal claims
 - The data subject has objected to processing pending the verification whether the legitimate grounds of the controller override those of the data subject

These rights are not absolute and exemptions may apply.

➔ Click each right to learn more.

Introduction to Data Protection and GDPR

The slide is titled "Rights of Data Subjects" in a dark blue header. The main content area has a grey background with a faint circular graphic. At the top, it says "The Regulation specifies certain rights of Data Subjects." Below this, there are several rights listed with blue checkmarks in circles: "Right to Rectification", "Right to be Forgotten", "Right to Access", and "Right to be Informed". A blue pop-up box titled "Right to Object" is overlaid on the slide. It contains three bullet points: "The data subject can object to their data being processed in certain circumstances", "On receiving such a request, the controller cannot process said data unless they can demonstrate compelling grounds for processing the data", and "There is an absolute right to object to direct marketing". At the bottom of the slide, it says "These rights are not absolute and exemptions may apply." and "Click each right to learn more." with a right-pointing arrow. Navigation icons (back, forward, search, etc.) are visible on the left and right sides of the slide.

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

- ✓ Right to Rectification
- ✓ Right to be Forgotten
- ✓ Right to Access
- ✓ Right to be Informed

Right to Object

- The data subject can object to their data being processed in certain circumstances
- On receiving such a request, the controller cannot process said data unless they can demonstrate compelling grounds for processing the data
- There is an absolute right to object to direct marketing

These rights are not absolute and exemptions may apply.

➔ Click each right to learn more.

Introduction to Data Protection and GDPR

The slide is titled "Rights of Data Subjects" in a dark blue header. The main content area has a grey background with a faint circular graphic. At the top, it says "The Regulation specifies certain rights of Data Subjects." Below this, there are several rights listed with blue checkmarks in circles: "Right to Rectification", "Right to be Informed" (which is highlighted by a modal window), "Right to Access", and "Right to be Forgotten". At the bottom, it says "These rights are not absolute and exemptions may apply." and "Click each right to learn more." with a right-pointing arrow. The modal window for "Right to be Informed" has a blue header with a close button (X) and a white body with three orange square bullet points.

Rights of Data Subjects

The Regulation specifies certain rights of Data Subjects.

- ✓ Right to Rectification
- ✓ Right to be Informed
 - Organisations must provide information to you and how they handle your data
 - Information must be provided when the data is collected
 - The information they give you must be clear, concise, transparent and intelligible
- ✓ Right to Access
- ✓ Right to be Forgotten

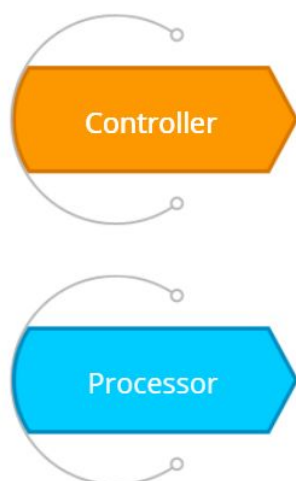
These rights are not absolute and exemptions may apply.

➔ Click each right to learn more.

Introduction to Data Protection and GDPR

Data Controllers and Data Processors

→ Click each term to view the definition.



'Controller' means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; Where, the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law.

Introduction to Data Protection and GDPR

Data Controllers and Data Processors

→ Click each term to view the definition.

Controller

Processor

'Processor' means a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller.

Introduction to Data Protection and GDPR

Responsibilities

The controller will:

- Implement appropriate technical and organisational measures to ensure and demonstrate conformance with the GDPR
- Adhere to approved codes of conduct and/or certification mechanisms
- Implement data protection measures
- Integrate the necessary safeguards into the processing
- Implement appropriate technical and organisational measures to ensure that only the required personal data are processed
- Maintain a record of processing activities under its responsibility



Controller
Responsibilities

Introduction to Data Protection and GDPR

Responsibilities

The processor will:

- Not engage another processor without prior specific or general written authorisation of the controller
- Maintain a record of processing activities carried out on behalf of a controller
- Make the record available to the supervisory authority on request



Processor Responsibilities

Introduction to Data Protection and GDPR

Security of Personal Data

The GDPR lays down certain security measures that controllers and processors should implement to ensure a level of security appropriate to the level of risk.

Security measures for personal data may include:

- Pseudonymisation and encryption
- Ability to ensure confidentiality, integrity, availability and resilience
- Ability to restore the availability and access to data
- Regular testing, assessment and evaluation of effectiveness of technical and organisational measures



Introduction to Data Protection and GDPR

Security of Personal Data

Data breach notification :

- Controller should notify the supervisory authority within 72 hours if the breach poses a risk to the rights and freedoms of data subjects
- Reasons for delay should be given if notification not given in the specified time
- Processor should notify the controller of a data breach without undue delays



Introduction to Data Protection and GDPR

Security of Personal Data

Data breach notification :

Controller should document any personal data breaches. The documentation will include :

- Facts of the breach
- Effects
- Remedial actions taken

In case of high risk personal data breaches:

- The controller will communicate incident to the data subject immediately
- The communication should be in a clear and plain language



Introduction to Data Protection and GDPR

Data Protection Impact Assessment



- ☒ The controller should undertake a Data Protection Impact Assessment (DPIA) where there may be a high risk to the data subjects in order to evaluate the potential impact of future processing operations on protection of personal data.
- ☒ The controller should seek advice of the Data Protection Officer (DPO) for conducting DPIA.

Contents of the DPIA

- Description of Processing operations and their purpose
- Assessment of necessity and proportionality
- Assessment of risks
- Measures to address the risks

Introduction to Data Protection and GDPR

Designation of a DPO

Where is a DPO required?

The controller and the processor should designate a data protection officer where:

- Processing is carried out by a public authority
- Processing operations require regular and systematic monitoring of data subjects
- Processing operations involve special categories of data and personal data relating to criminal convictions and offences



Introduction to Data Protection and GDPR

Tasks and Responsibilities



The Data Protection Officer will:

- Inform the relevant parties of their obligations
- Monitor compliance
- Provide advice regarding DPIA and monitor performance
- Cooperate with the supervisory authorities
- Act as contact point on issues related to processing

Introduction to Data Protection and GDPR

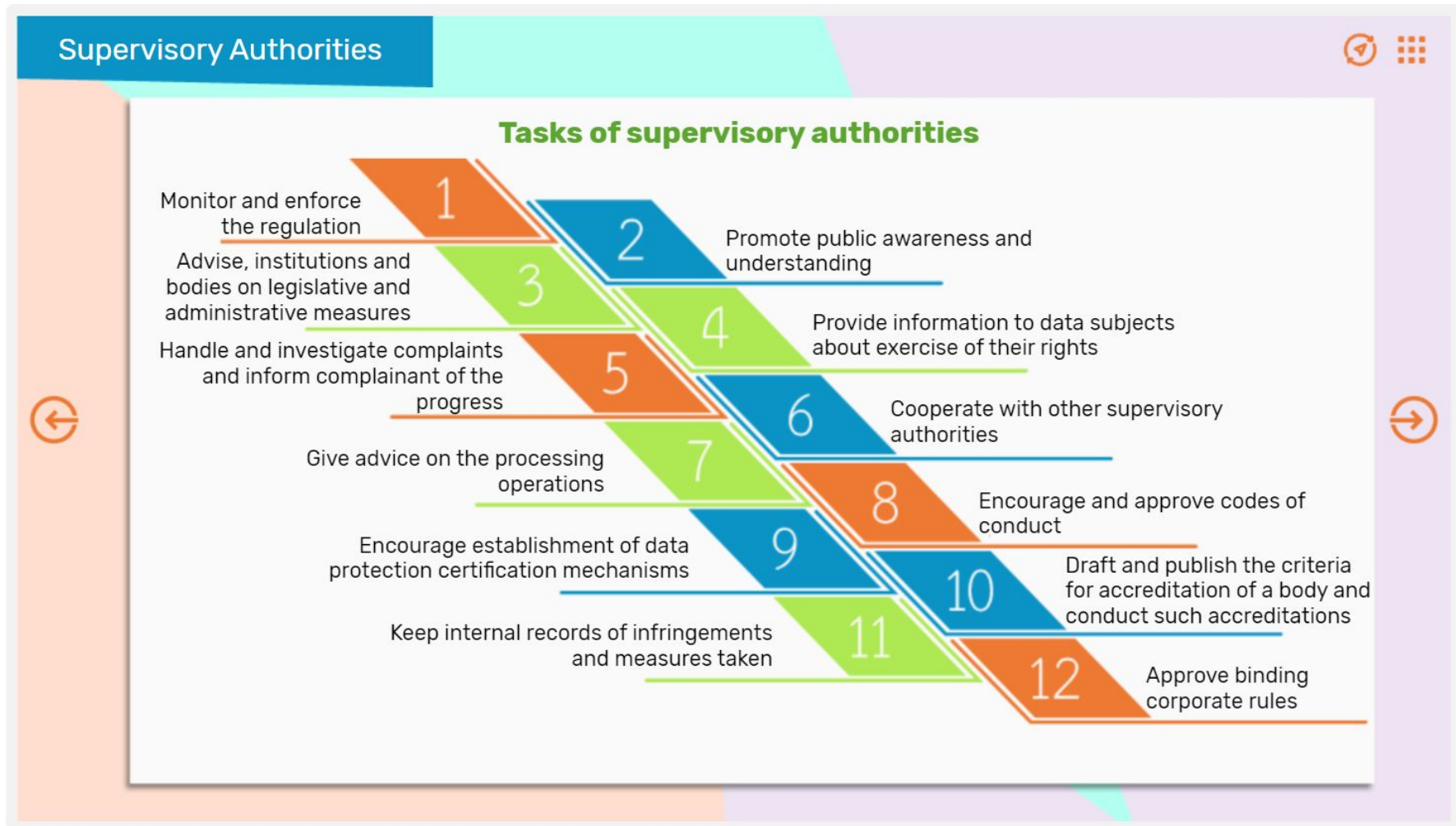
Regulatory Authorities

Supervisory authorities are:

- Independent public authorities
- Responsible for monitoring the application of GDPR

These authorities must be given complete independence in the performance of their duties under GDPR.

Introduction to Data Protection and GDPR



Introduction to Data Protection and GDPR

European Data Protection Board

The GDPR established the European Data Protection Board.

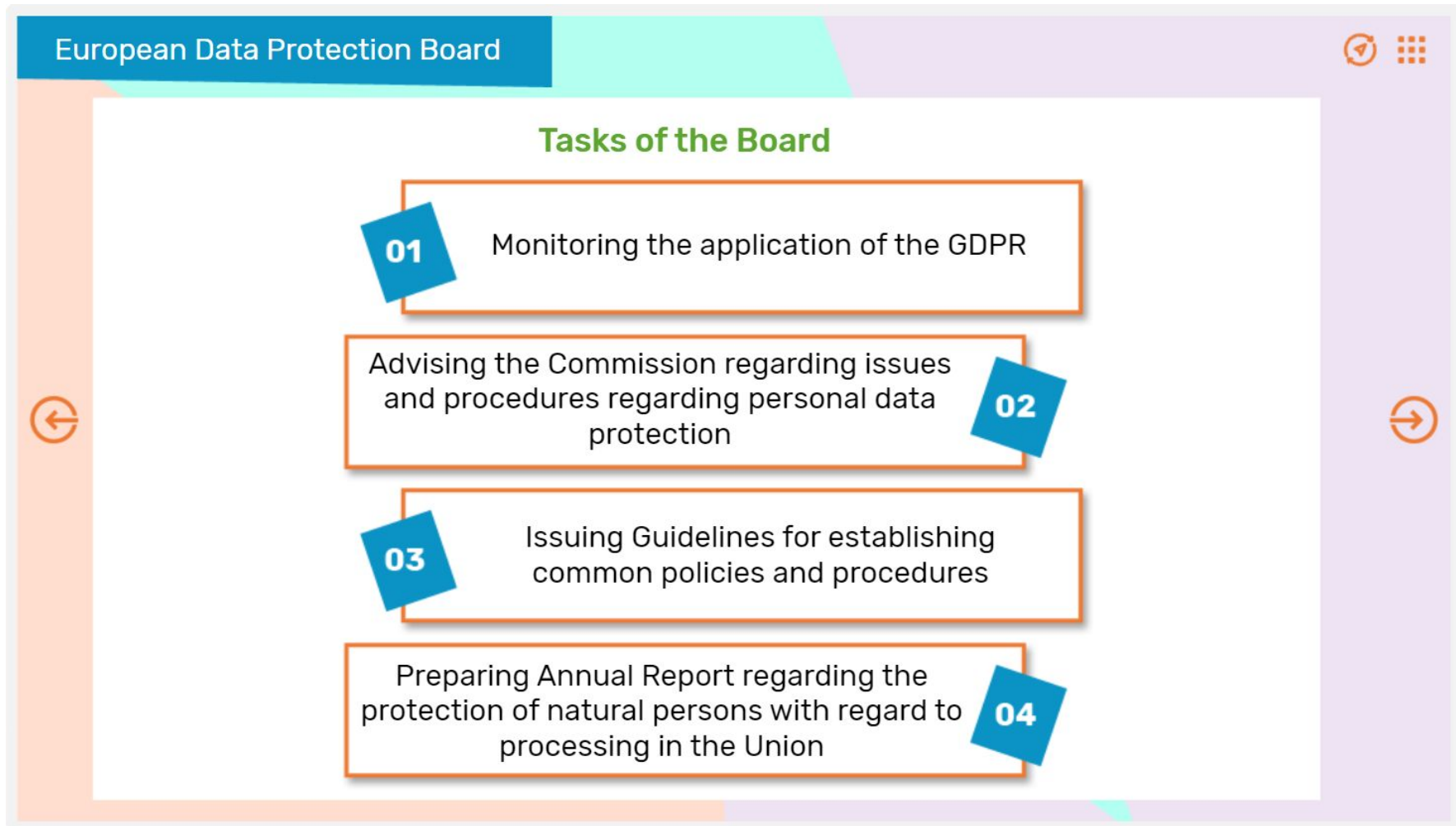


European Data Protection Board will be composed of the:

- Head of Supervisory Authorities (one per state)
- European Data Protection Supervisor

The Board will act independently during the performance of its tasks or exercise of its powers.

Introduction to Data Protection and GDPR



Introduction to Data Protection and GDPR

Consequences of Non-Compliance

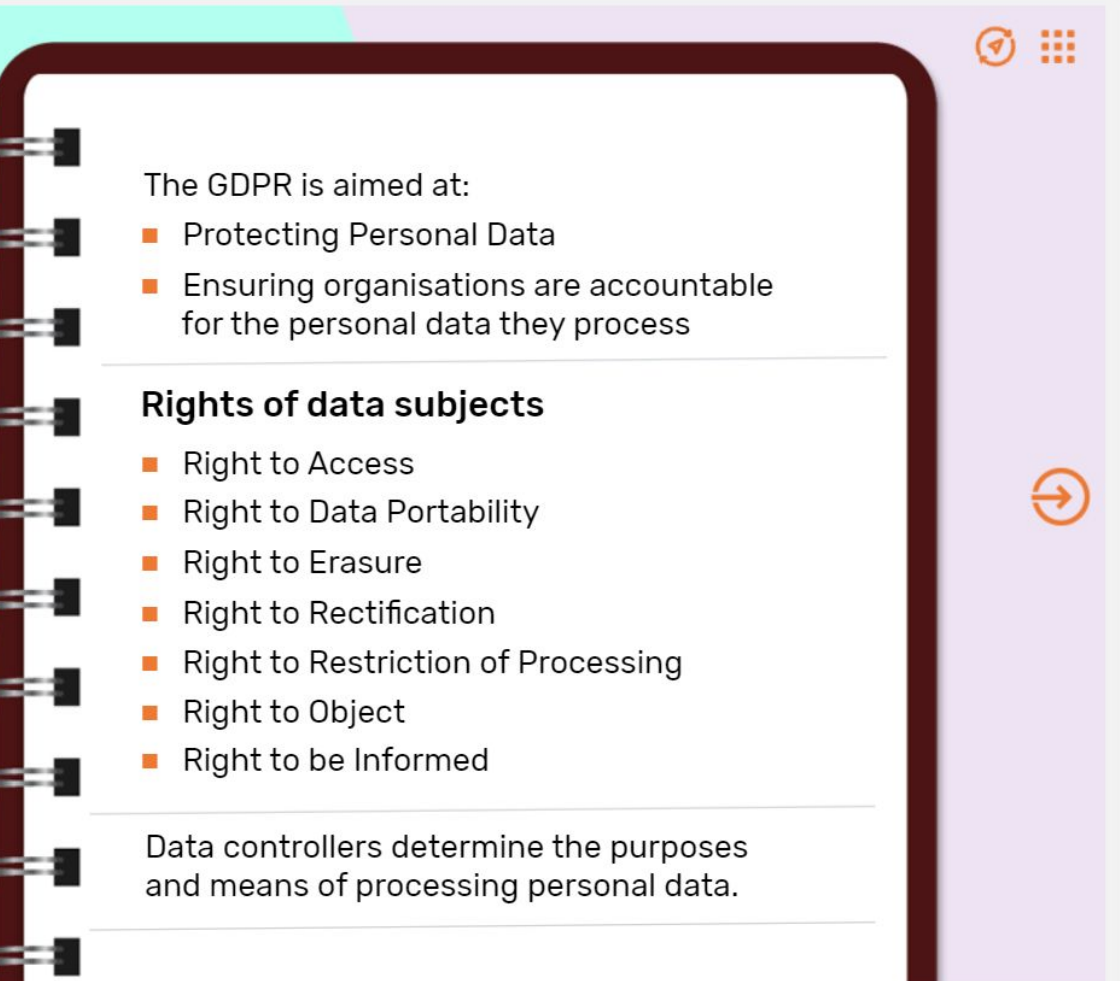
The GDPR provides two levels of fines depending on the severity of the breach.

Introduction to Data Protection and GDPR

Consequences of Non-Compliance	
Fine Amount	Breach of Regulation
2% of global annual revenue or €10 million, whichever is higher	Data Breaches
	Incomplete records
	Not conducting DPIA
	Not employing services of a DPO
	Failing to get certification of security measures
4% of global annual revenue or €20 million, whichever is higher	Failing to get consent
	Not upholding rights of data subjects

Introduction to Data Protection and GDPR

Summary



The GDPR is aimed at:

- Protecting Personal Data
- Ensuring organisations are accountable for the personal data they process

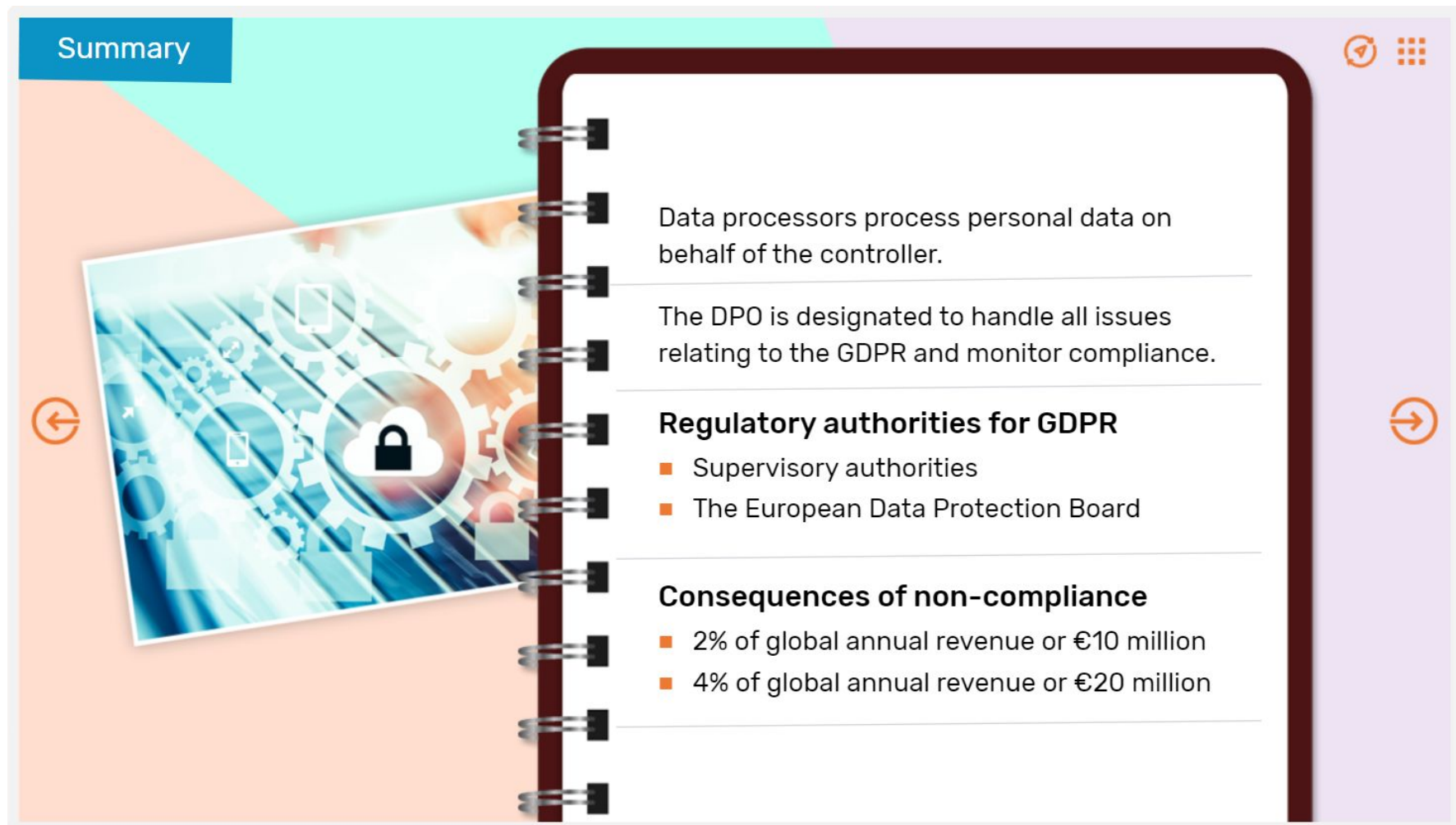
Rights of data subjects

- Right to Access
- Right to Data Portability
- Right to Erasure
- Right to Rectification
- Right to Restriction of Processing
- Right to Object
- Right to be Informed

Data controllers determine the purposes and means of processing personal data.

Introduction to Data Protection and GDPR

Summary



Data processors process personal data on behalf of the controller.

The DPO is designated to handle all issues relating to the GDPR and monitor compliance.

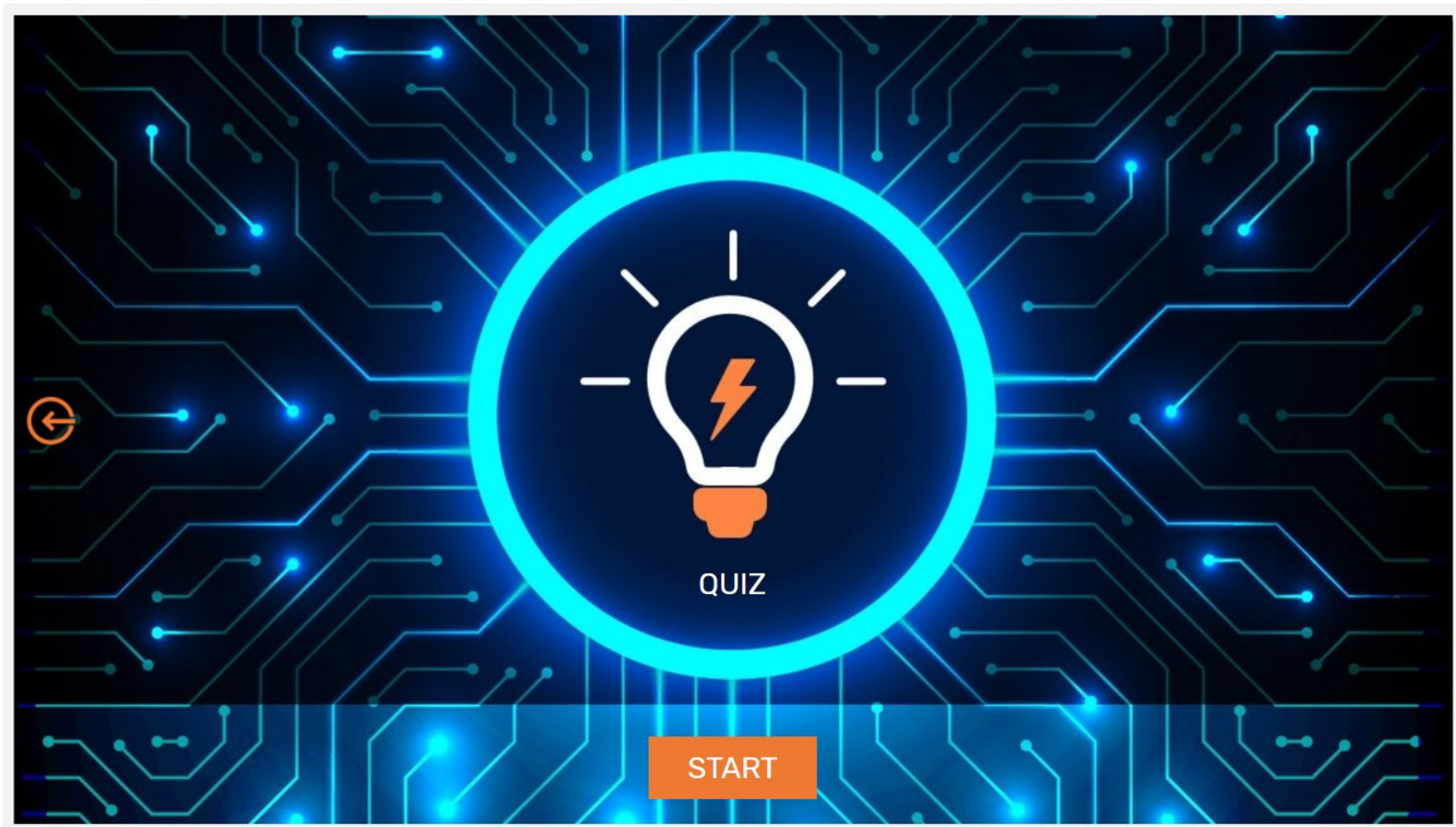
Regulatory authorities for GDPR

- Supervisory authorities
- The European Data Protection Board

Consequences of non-compliance

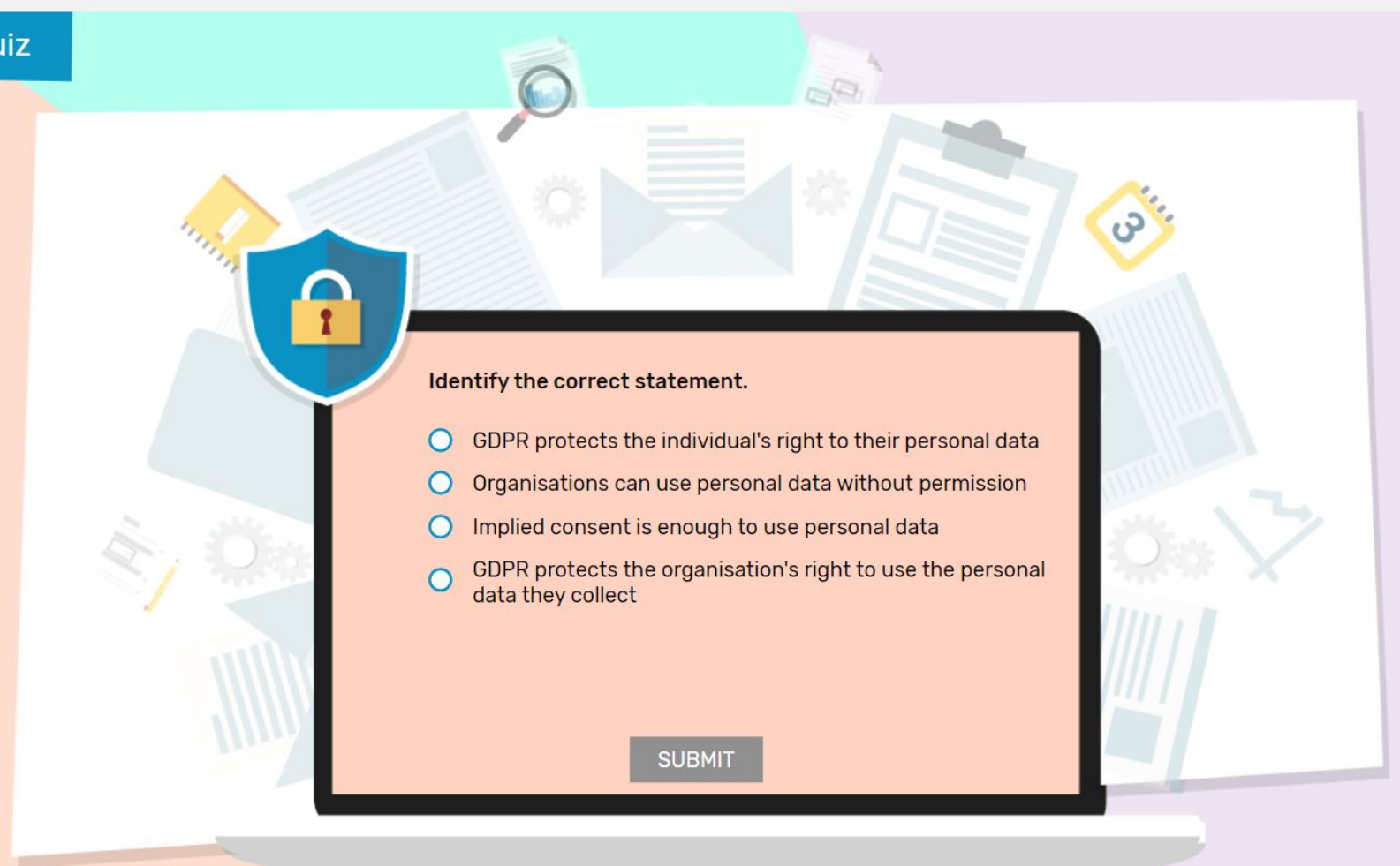
- 2% of global annual revenue or €10 million
- 4% of global annual revenue or €20 million

Introduction to Data Protection and GDPR



Introduction to Data Protection and GDPR

Quiz



Identify the correct statement.

- ☐ GDPR protects the individual's right to their personal data
- ☐ Organisations can use personal data without permission
- ☐ Implied consent is enough to use personal data
- ☐ GDPR protects the organisation's right to use the personal data they collect

SUBMIT

Introduction to Data Protection and GDPR

Quiz

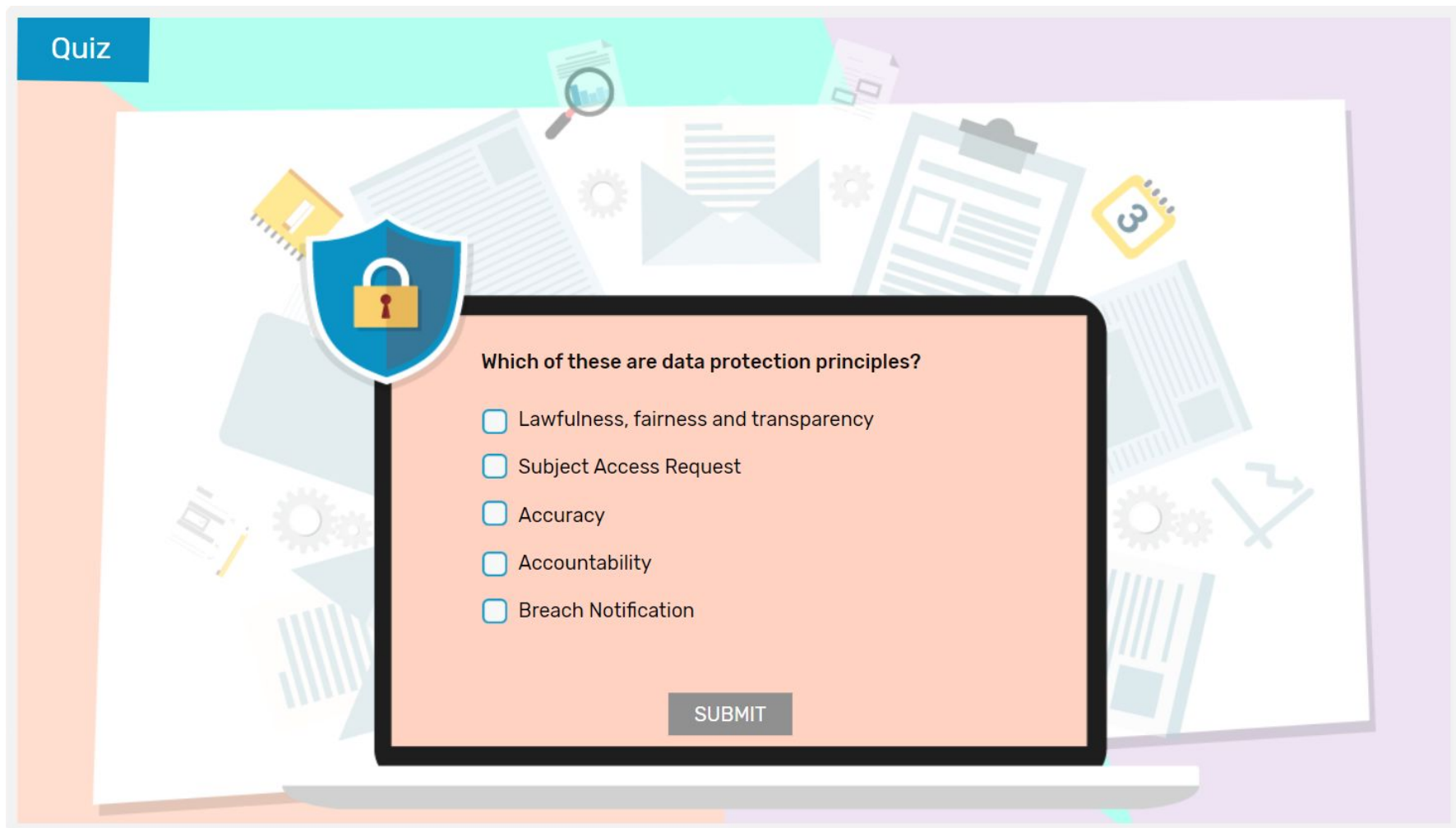
 Drag the each right to match its respective statement.

John sends a data transfer request to morale data services	Drop content here	Right to Data Portability
Excel Services receives a request for information regarding personal data	Drop content here	Right to be Informed
Mary sends an address correction request to her Telecom operator	Drop content here	Right to Rectification
Monarch Software let their client know that they will be sharing their data with another company	Drop content here	Right to Access

SUBMIT

Introduction to Data Protection and GDPR

Quiz



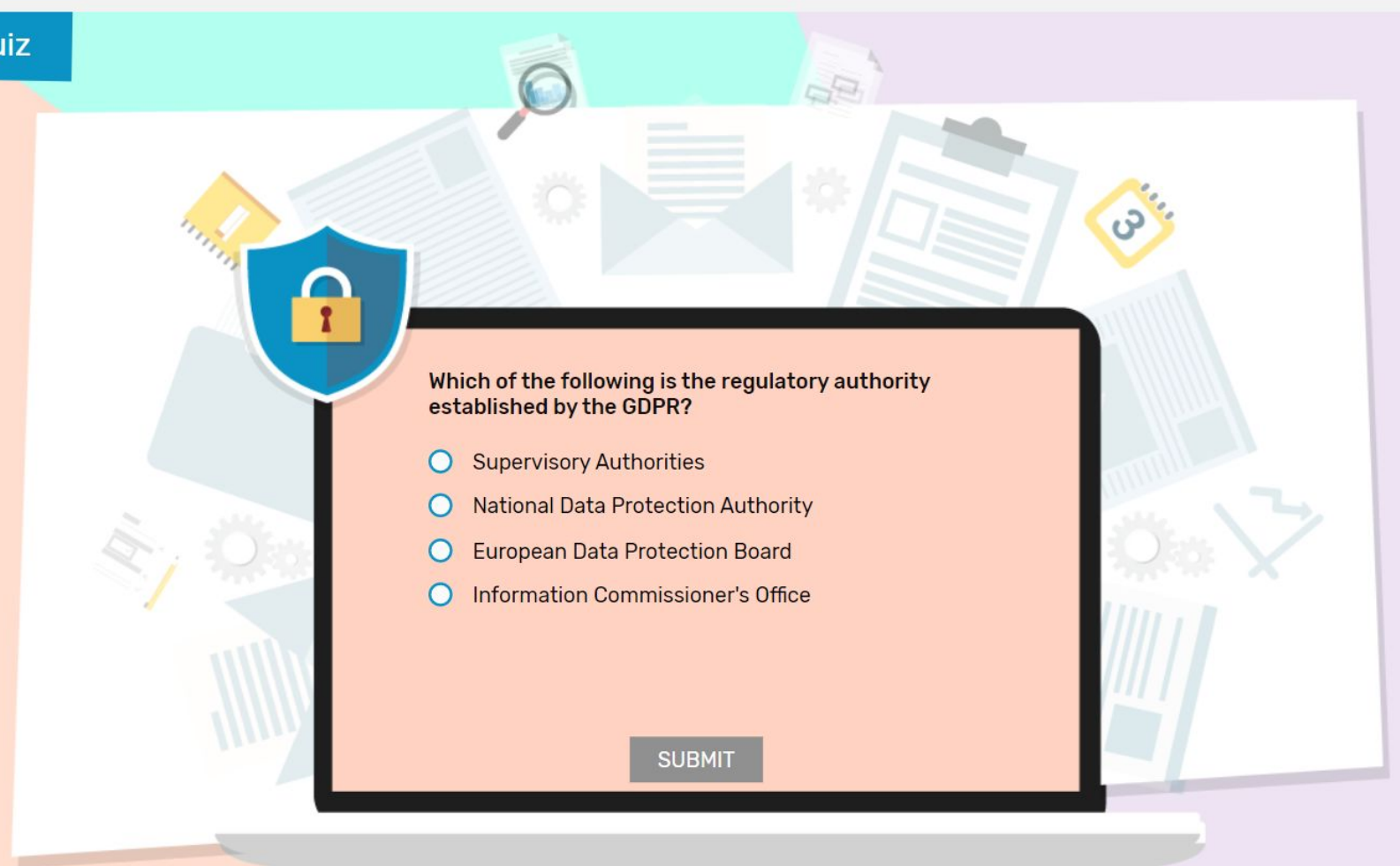
Which of these are data protection principles?

- ☐ Lawfulness, fairness and transparency
- ☐ Subject Access Request
- ☐ Accuracy
- ☐ Accountability
- ☐ Breach Notification

SUBMIT

Introduction to Data Protection and GDPR

Quiz



Which of the following is the regulatory authority established by the GDPR?

- ☐ Supervisory Authorities
- ☐ National Data Protection Authority
- ☐ European Data Protection Board
- ☐ Information Commissioner's Office

SUBMIT

Introduction to Data Protection and GDPR

Quiz



The first level of fines under GDPR is 2.5% of global annual revenue or 10 million.

☐ True

☐ False

SUBMIT

Introduction to Data Protection and GDPR



Congratulations!
You have successfully completed this
lesson.